DOCUMENTO

Evaluación · NIST CSF 2.0 (Cyber AI Profile), NIST AI RMF por perfiles e ISO/IEC 42001 en SEVEN-G

Documento de trabajo (no publicable). 25-09-2026.

Fernando García Varela

EN ESTE DOCUMENTO

01 Propuesta evaluada

02 Veredicto

03 Qué hay hoy en SEVEN-G

04 Estado de las fuentes (D41)

05 Qué habría que modificar o incluir

06 Esfuerzo y orden sugerido

07 Decisiones que necesita el autor

> **Estado de ejecución (25-09-2026).** Las cuatro decisiones de la sección 7 se han aplicado con las recomendaciones (escala 0–5 con equivalencia a los *tiers*; entregas 1 a 3; el Cyber AI Profile se cita como borrador; plantilla P74). **Hechas:** entrega 1, mapeo del CSF 2.0 y del Cyber AI Profile en 34 §5.3 y columna «Función CSF» en el 35 (D110); entrega 2, perfiles por subcategoría en 34 §5.4–§5.5 y equivalencia en 11 §2.2 y §7.5 (D111); entrega 3, plantillas P72, P73 y P74 (D112). Verificado en csrc.nist.gov el 25-09-2026: el Cyber AI Profile sigue en borrador preliminar (iprd, 16-12-2025). **Sin hacer, a la espera del autor:** entrega 4 (vistas de perfil en T15, esquema 0.7 de T01 y brecha en T17) y entrega 5 (contenido «Defend» en el 35).

01

Propuesta evaluada

1. Seguridad de los sistemas de IA: evaluarla con los *tiers* del NIST CSF, a través del Cyber AI Profile .
2. Gobierno de la IA (sesgo, transparencia, responsabilidad, supervisión humana): usar el NIST AI RMF con perfiles actual y objetivo y una escala de madurez propia (por ejemplo, de 1 a 4 por subcategoría) que reutilice la lógica de los *tiers*.
3. Para algo certificable: usar la correspondencia entre el AI RMF e ISO/IEC 42001 .

02

Veredicto

Sí aplica y encaja con SEVEN-G, que ya «mapea, no incrusta» (34 §1.1), pero con tres correcciones:

- **Los *tiers* del CSF no son niveles de madurez por subcategoría.** El CSF 2.0 los define para toda la organización (o una unidad): describen el rigor de su gobierno y de su gestión del riesgo de ciberseguridad (1 Parcial, 2 Informado por el riesgo, 3 Repetible, 4 Adaptativo). Los perfiles actual y objetivo se expresan con los resultados (subcategorías) que se alcanzan o se quieren alcanzar. Puntuar cada subcategoría de 1 a 4 es una convención propia. Es legítima si se declara como tal, pero no debe presentarse como «tier del CSF».
- **El AI RMF no tiene *tiers* ni escala de madurez.** Solo tiene funciones, categorías, subcategorías y perfiles. La escala se añade por encima.
- **SEVEN-G ya tiene una escala: 0–5 (documento 11, D20)**, con reglas de acumulación, evidencia, requisitos temporales en los niveles 4 y 5 y el límite de D1/D6. Añadir una segunda escala de 1 a 4 haría que el consejo viera dos números distintos para lo mismo. **Recomendación: puntuar los perfiles con la escala 0–5 de SEVEN-G y dar una tabla de equivalencia con los *tiers*** para quien viene del CSF.

Nivel SEVEN-G (11 §2.2)	Equivalencia orientativa	Motivo
0 Inexistente · 1 Inicial	Tier 1 · Parcial	Práctica *ad hoc* y reactiva
2 En desarrollo	Tier 2 · Informado por el riesgo	Aprobada, pero no aplicada en toda la organización
3 Definido	Tier 3 · Repetible	Política formal aplicada a todo el perímetro
4 Gestionado · 5 Optimizado	Tier 4 · Adaptativo	Se mide, se ajusta y mejora con datos propios

La equivalencia es aproximada: los *tiers* no exigen evidencia de dos trimestres (nivel 4) ni un ciclo C5 completo (nivel 5). Si se ofrece una vista de 1 a 4, será solo una vista calculada desde el 0–5, nunca una captura aparte.

03

Qué hay hoy en SEVEN-G

Referencia	Cobertura actual	Hueco
NIST AI RMF 1.0	01 §13 (funciones → fases); 34 §5.1, las **19 categorías** (GOVERN 1 … MANAGE 4) con fase, rol, evidencia y herramienta; 33 §1	No baja a las **subcategorías**, que son la unidad de un perfil. No hay perfil actual ni objetivo.
NIST AI 600-1	34 §5.2; riesgos tipo GEN/SEG/TER en el documento 33	—
ISO/IEC 42001	34 §4.1 (cláusulas 4–10), 34 §4.2 (anexo A por grupo), 38 §12 (auditoría interna), 01 §13; D25: SEVEN-G no certifica	No hay plantilla de **declaración de aplicabilidad** (6.1.3) ni una correspondencia AI RMF ↔ 42001 propia
NIST CSF 2.0	**Nada.** No aparece en ningún documento ni en el registro de referencias	Todo
Cyber AI Profile (NIST IR 8596)	**Nada**	Todo, pero es un borrador (§4)
Seguridad de la IA	35: amenazas (OWASP, ATLAS, 600-1), SEG-01…20, AG-, A0–A3, IA ofensiva (§9), indicadores (§10)	No se expresa con las funciones del CSF (GV, ID, PR, DE, RS, RC) ni con un perfil

04

Estado de las fuentes (D41)

- **Cyber AI Profile**: NIST publicó el borrador preliminar de NIST IR 8596 el 16-12-2025, con comentarios hasta el 30-01-2026, y anunció un borrador público inicial para 2026. Hay indicios de que ese borrador ya existe (página «ipd» en NCCoE), pero no he podido abrir `nist.gov` ni `nccoe.nist.gov` desde esta sesión (el proxy los bloquea). **Hay que verificarlo con el navegador antes de citarlo.** Mientras sea borrador, se cita marcado «Borrador» (34 §1.4) y como orientación, nunca como base de un criterio de *gate*. Su estructura en tres áreas —**Secure** (proteger los componentes de los sistemas de IA), **Defend** (usar la IA en la ciberdefensa) y **Thwart** (frustrar ataques que usan IA)— encaja con el documento 35.
- **CSF 2.0** (NIST CSWP 29, febrero de 2024): versión final. Debe darse de alta en `g5_normas_marcos.json`.
- **Correspondencia AI RMF ↔ ISO/IEC 42001**: el centro de recursos de IA de NIST aloja una correspondencia hecha sobre el borrador final de la norma (FDIS), anterior a la publicación de diciembre de 2023. Sirve como orientación, pero hay que cotejarla con la norma publicada. El AI

RMF **no es certificable**; lo certificable es ISO/IEC 42001, a través de una entidad acreditada (17021-1 y 42006; 38 §12).

05

Qué habría que modificar o incluir

5.1 Necesario (propuesta)

#	Cambio	Dónde	Por qué
1	Nueva sección «NIST CSF 2.0 y Cyber AI Profile» con la tabla del mismo formato: función CSF (GV, ID, PR, DE, RS, RC) → fase o etapa, rol, evidencia y herramienta; y el Cyber AI Profile por áreas (Secure → 35 §3–§8 y SEG/AG; **Defend** → hueco; Thwart → 35 §9, SEG-15…19)	34 (nueva §5.3 o §7.3), 01 §13, matriz del 34 §9	Quien viene del CSF encuentra dónde cae cada cosa sin salir de SEVEN-G
2	Columna «Función CSF» en los catálogos SEG y AG	35 §6–§7	Permite construir el perfil de seguridad desde los controles existentes
3	**Perfil actual y objetivo de seguridad de IA** (por subcategoría CSF relevante para IA, en la escala 0–5, con la equivalencia del §2)	Nuevo 35 §10.x + plantilla nueva (P72)	Es la evaluación que pide la propuesta, sin crear una segunda escala
4	**Perfil actual y objetivo del AI RMF por subcategoría** (GOVERN 1.1 … MANAGE 4.3), en la escala 0–5, con las evidencias SEVEN-G y la brecha priorizada	34 §5.1 (bajar a subcategorías) + plantilla nueva (P73)	Los perfiles se construyen sobre subcategorías; hoy SEVEN-G se queda en las categorías
5	Regla de cálculo: el nivel de cada subcategoría se **deriva de las preguntas del cuestionario del 11** cuando existen (D1–D7), y solo se pregunta aparte lo que no cubren	11 §7 (nuevo vínculo)	Una sola evaluación, dos lecturas; se evita la doble captura
6	Tabla de equivalencia 0–5 ↔ *tiers* y advertencia de que no son lo mismo	11 §2.2 y 02 (glosario: «tier», «perfil actual», «perfil objetivo»)	Los lectores del CSF entienden el resultado
7	Plantilla de **declaración de aplicabilidad de ISO/IEC 42001** (controles del anexo A, aplicable o no, justificación, dónde lo cubre SEVEN-G y su evidencia) y correspondencia AI RMF → 42001 → SEVEN-G	Plantilla nueva (P74); 34 §4.2	Es la pieza que una compañía necesita para pasar de «alineada» a «certificable». SEVEN-G sigue sin certificar (D25)
8	Referencias nuevas (CSF 2.0, NIST IR 8596 marcado como borrador y la correspondencia de AIRC) en el registro, verificadas	`SEVEN-G/build/referencias/g5_normas_marcos.json`	D41

#	Cambio	Dónde	Por qué
9	Todo lo anterior también en inglés	`mds/en/`	D12

5.2 Herramienta

Lo más barato es **ampliar T15** (diagnóstico de madurez), que ya tiene la escala 0–5, las evidencias, el informe y la comparación en el tiempo. Añadiría dos vistas: «Perfil de seguridad (CSF / Cyber AI)» y «Perfil de gobierno (AI RMF)», cada una con su columna de nivel actual y objetivo, la brecha y la equivalencia con los *tiers*. El resumen iría a `madurez[]` de T01 como campo opcional (esquema 0.7, D53) y el panel T17 podría mostrar la brecha. Si se hace, hay que actualizar `mapa_datos.json`, el 03 §4.1, el conector en Python y en JS (19b) y la prueba de humo.

5.3 Lo que no recomiendo

- **Adoptar la escala de 1 a 4 como escala oficial.** Rompe D20 y obligaría a recalibrar el documento 11, T15, T01, T17 y el índice (12 §7.2).
- **Basar criterios de *gate* en el Cyber AI Profile** mientras sea borrador.
- **Prometer que la correspondencia con 42001 hace a la compañía certificable.** Solo lo facilita (38 §12; D25).

5.4 Hueco de fondo que revela el Cyber AI Profile

El área **Defend** (usar IA en la ciberdefensa de la compañía) no está en el 35, que trata la IA como algo que proteger (Secure) o como amenaza (Thwart). Encaja como caso de uso en la esfera correspondiente del documento 10 y con criterios propios en el 35 (supervisión humana de la respuesta automatizada, falsos positivos, autonomía A2/A3 en la respuesta a incidentes). Esto sí es contenido nuevo, no solo un mapeo.

06

Esfuerzo y orden sugerido

1. Verificar las fuentes (§4) y darlas de alta en el registro de referencias.
2. Añadir la sección CSF y Cyber AI del 34 y la columna CSF del 35 (ES/EN). Es mapeo puro y no añade reglas.
3. Bajar el AI RMF a subcategorías, con la equivalencia 0–5 ↔ *tiers* (11, 02, 34).
4. P72–P74 (perfiles y declaración de aplicabilidad) en ES/EN y en Word (D67).
5. Ampliar T15 y el esquema de T01 a 0.7, y la tarjeta de brecha en T17.

6. Contenido «Defend» en el 35.

Del 1 al 3: documental, sin tocar herramientas. Del 4 al 6: plantillas, esquema y paneles. Hacen falta las comprobaciones de `verificar_coherencia.ps1` (paridad ES/EN, referencias, prueba de humo de T15).

07

Decisiones que necesita el autor

- ¿Se usa la escala 0–5 con equivalencia a los *tiers* (recomendado) o se acepta una segunda escala de 1 a 4?
- ¿Solo mapeo (pasos 1–3) o también perfiles con herramienta (pasos 4–5)?
- ¿Se incorpora «Defend» como contenido nuevo del 35?
- ¿Se ofrece la plantilla de declaración de aplicabilidad de 42001, sabiendo que exige cotejarla con el texto adquirido de la norma?

Fuentes externas citadas

Enlaces a la fuente oficial o primaria, comprobados antes de publicar. Verifique siempre la versión vigente en la fecha de uso.

Marco de gestión de riesgos de IA: perfil de inteligencia artificial generativa (NIST AI 600-1) · https://www.nist.gov/publications/artificial-intelligence-risk-management-framework-generative-artificial-intelligence · National Institute of Standards and Technology (NIST) · 26-07-2024

Perfil del marco de ciberseguridad para la inteligencia artificial (Cyber AI Profile): perfil comunitario del NIST, NIST IR 8596 (borrador preliminar inicial) · https://csrc.nist.gov/pubs/ir/8596/iprd · National Institute of Standards and Technology (NIST), NCCoE · 16-12-2025

ISO/IEC 42001:2023 Tecnología de la información — Inteligencia artificial — Sistema de gestión · https://www.iso.org/standard/42001 · ISO/IEC (JTC 1/SC 42) · 18-12-2023

Marco de ciberseguridad del NIST, versión 2.0 (The NIST Cybersecurity Framework (CSF) 2.0), NIST CSWP 29 · https://doi.org/10.6028/NIST.CSWP.29.spa · National Institute of Standards and Technology (NIST), Departamento de Comercio de EE. UU. · 26-02-2024

Marco de gestión de riesgos de inteligencia artificial del NIST (AI RMF 1.0), NIST AI 100-1 · https://www.nist.gov/publications/artificial-intelligence-risk-management-framework-ai-rmf-10 ·

National Institute of Standards and Technology (NIST), Departamento de Comercio de EE. UU. · 26-01-2023